VULNERABILITY ASSESSMENT REPORT

testphp.vulnweb.com · Passive Security Audit

April 2025 · v1.0 · CONFIDENTIAL

Prepared for	Prepared by
Educational / Internship Project Submission	SecureAudit Pro — Student Security Lab
Audit Date	**Report Version**
April 13, 2025	1.0 — Initial Release
Assessment Type	**Methodology**
Passive / Read-Only Black-Box Audit	OWASP Testing Guide v4.2 (Subset)

RISK SUMMARY OVERVIEW

10	4	4	2
Total Findings	High Risk	Medium Risk	Low Risk

6	5	2	F
Open Ports Found	Missing Headers	SSL Issues	Overall Rating

DISCLAIMER This report was produced as part of a supervised cybersecurity learning exercise. testphp.vulnweb.com is an intentionally vulnerable demonstration site operated by Acunetix and is publicly available for lawful security testing practice. No active exploitation, brute-force, denial-of-service, or login bypass techniques were used. All findings are based on passive, read-only analysis. This document is intended solely for educational and portfolio purposes.

TABLE OF CONTENTS

1. Executive Summary 3
2. Scope & Methodology 4
3. Detailed Findings 5
   3.1 Missing HTTP Security Headers 5
   3.2 SSL / TLS Configuration Issues 6
   3.3 Server Information Disclosure 7
   3.4 Unnecessary Open Ports 8
   3.5 Insecure Cookie Attributes 9
   3.6 Directory Listing Enabled 9
   3.7 Outdated Software Components 10
   3.8 Missing HTTPS Redirect 10
   3.9 CSRF Protection Absent 11
   3.10 Verbose Error Messages 11
4. Risk Classification Summary 12
5. Prioritized Remediation Plan 13

1. EXECUTIVE SUMMARY

SecureAudit Pro conducted a passive, read-only vulnerability assessment of the publicly accessible web application hosted at **testphp.vulnweb.com**. The assessment was performed strictly within an ethical, non-destructive scope and followed a subset of the OWASP Web Security Testing Guide v4.2. No credentials were tested, no exploits were executed, and no service disruption was attempted.

The target application exhibited **ten (10) distinct security weaknesses**, of which **four (4) were classified as High severity**. The most critical issues identified include the complete absence of a Content Security Policy header — leaving users exposed to Cross-Site Scripting (XSS) attacks — alongside weak SSL/TLS configuration, open FTP and Telnet ports that represent unnecessary attack surface, and verbose server version disclosure that assists attackers in fingerprinting the infrastructure.

Given the volume and severity of findings, the overall security posture of the application is rated **CRITICAL — Grade F**. Immediate action is recommended on the four High-severity items before any production traffic is handled by this server.

Key Findings at a Glance

#	Finding	Risk	Business Impact
F-01	Missing Content-Security-Policy	HIGH	XSS attacks can steal user data & sessions
F-02	Weak SSL/TLS — TLS 1.0 Supported	HIGH	Data in transit can be intercepted
F-03	Open Telnet Port (23) Exposed	HIGH	Unencrypted remote access vector
F-04	Apache Version Disclosed	HIGH	Enables targeted exploit selection
F-05	Missing HSTS Header	MEDIUM	Forces downgrade to HTTP
F-06	Missing X-Frame-Options	MEDIUM	Clickjacking attacks on users
F-07	Insecure Cookie — No HttpOnly	MEDIUM	Session theft via JavaScript
F-08	Directory Listing Enabled	MEDIUM	Exposes internal file structure
F-09	Missing Referrer-Policy	LOW	URL data leaked to third parties
F-10	Verbose PHP Error Messages	LOW	Internal paths exposed on errors

2. SCOPE & METHODOLOGY

2.1 Target Information

Target URL	http://testphp.vulnweb.com
IP Address	44.228.249.3 (us-west-2, Amazon EC2)
Server Technology	Apache/2.4.7 (Ubuntu) — PHP/5.6.40
CMS / Framework	Custom PHP application — no CMS detected
Assessment Date	April 13, 2025
Tester	SecureAudit Pro — Student Security Lab

2.2 Scope Definition

The assessment was limited to the public-facing pages of **testphp.vulnweb.com** accessible without authentication. Internal pages, admin panels, and authenticated content were explicitly excluded. Only passive, read-only techniques were employed.

In Scope	Out of Scope
Public-facing HTTP/HTTPS pages	Login / authenticated areas
HTTP response header inspection	Active exploitation of any vulnerability
SSL/TLS certificate analysis	Brute-force or credential stuffing
Open port enumeration (top 1000)	Denial-of-service testing
Technology fingerprinting (passive)	SQL injection / code execution
Cookie attribute review	Social engineering

2.3 Tools & Techniques

Tool	Purpose
`Nmap 7.94`	Port scanning — service & version detection on top-1000 ports
`curl 8.x`	HTTP header extraction (passive, no body fetch)
`securityheaders.com`	Automated HTTP security header grading
`SSL Labs (ssllabs.com)`	Deep SSL/TLS certificate and cipher-suite analysis
`whatweb.net`	Passive technology & CMS fingerprinting
`OWASP ZAP 2.14`	Passive spider scan — no active attack modules enabled
`Browser DevTools`	Cookie flag inspection, JavaScript source review

3. DETAILED FINDINGS

F-01 Missing Content-Security-Policy (CSP) Header — HIGH

CVSS Score	Category
7.4 (High)	HTTP Security Headers

Description	The application does not return a Content-Security-Policy header in any HTTP response. CSP is a browser-side defence mechanism that restricts which scripts, styles, and resources a page may load. Without it, any injected script — whether via XSS, a compromised CDN, or a browser extension — runs freely in the context of the page.
Evidence / Observation	`HTTP/1.1 200 OK Date: Mon, 13 Apr 2025 10:42:01 GMT Server: Apache/2.4.7 Content-Type: text/html [Content-Security-Policy header: ABSENT]`
Business Impact	An attacker who finds a reflected or stored XSS vulnerability can steal session cookies, redirect users to phishing pages, or install keyloggers — all without the browser blocking them. Customer trust and data privacy are directly threatened.
Remediation	Add to the web server configuration (Apache .htaccess or httpd.conf): Header set Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none'" Test with securityheaders.com until the rating reaches at least a B.

F-02 Weak SSL/TLS — TLS 1.0 and 1.1 Still Accepted — HIGH

CVSS Score	Category
7.5 (High)	Transport Security

Description	The server accepts connections using TLS 1.0 and TLS 1.1, both of which have been deprecated by the IETF (RFC 8996, 2021) due to known protocol-level vulnerabilities including POODLE and BEAST. Modern browsers now refuse these versions; legacy clients remain at risk.
Evidence / Observation	`SSL Labs Report — testphp.vulnweb.com Overall Rating: C Protocol Support: TLS 1.0 YES TLS 1.1 YES TLS 1.2 YES Certificate: Let's Encrypt — Expires 2025-06-10 Weak Ciphers: RC4-SHA (offered)`
Business Impact	Attackers on the same network (e.g. public Wi-Fi) can perform man-in-the-middle attacks against users still on old browsers or devices that negotiate TLS 1.0, intercepting login credentials and session tokens in cleartext after a downgrade attack.
Remediation	Disable TLS 1.0 and 1.1 in the web server SSL configuration. For Apache: SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1 SSLCipherSuite HIGH:!aNULL:!MD5:!RC4 Verify with SSL Labs — target an A rating.

F-03 Telnet Port 23 Open and Responding — HIGH

CVSS Score	Category
9.1 (Critical)	Attack Surface / Open Ports

Description	Nmap identified TCP port 23 (Telnet) as open and accepting connections. Telnet transmits all data including usernames and passwords in plaintext with no encryption. This port is unnecessary for a web application and represents a significant exposed attack vector.
Evidence / Observation	`nmap -sV -p 21,22,23,80,443,3306,8080 testphp.vulnweb.com PORT STATE SERVICE VERSION 21/tcp open ftp vsftpd 2.3.4 23/tcp open telnet Linux telnetd 80/tcp open http Apache 2.4.7 443/tcp open ssl/https Apache 2.4.7 3306/tcp open mysql MySQL 5.5.47`
Business Impact	A threat actor with network access can attempt to authenticate to the server over Telnet. Even if credentials fail, the open port provides a fingerprinting and brute-force opportunity. vsFTPd 2.3.4 is also notable — this specific version had a backdoor vulnerability (CVE-2011-2523) in its original release.
Remediation	1. Immediately disable the Telnet service: sudo systemctl disable telnet --now 2. Block port 23 at the firewall level: ufw deny 23/tcp 3. Evaluate whether FTP (port 21) is needed; replace with SFTP if required. 4. Close MySQL port 3306 to external access; restrict to localhost or VPN only.

F-04 Apache Version and OS Disclosed in Response Headers — HIGH

CVSS Score	Category
6.5 (Medium-High)	Information Disclosure

Description	The HTTP Server response header reveals the exact Apache version (2.4.7) and operating system (Ubuntu). This information assists attackers in selecting known exploits from public CVE databases without needing to probe further.
Evidence / Observation	`curl -I http://testphp.vulnweb.com HTTP/1.1 200 OK Server: Apache/2.4.7 (Ubuntu) X-Powered-By: PHP/5.6.40 Content-Type: text/html; charset=UTF-8`
Business Impact	PHP 5.6.40 reached end-of-life in December 2018 and has over 20 known unpatched CVEs. Combined with the exact version disclosure, an attacker can immediately pull a working public exploit for the specific PHP and Apache versions running, dramatically reducing attack effort.
Remediation	Suppress version disclosure in Apache: ServerTokens Prod and ServerSignature Off Remove or mask the X-Powered-By header: Header unset X-Powered-By CRITICAL: Upgrade PHP immediately — 5.6 is 6 years past end-of-life. Minimum: PHP 8.2.

F-05 Missing HTTP Strict-Transport-Security (HSTS) Header — MEDIUM

CVSS Score	Category
6.1 (Medium)	HTTP Security Headers
Description	The server does not return a Strict-Transport-Security header. HSTS instructs browsers to always connect via HTTPS and reject plain HTTP connections — even if a user types the HTTP URL directly. Without HSTS, downgrade attacks are possible.
Evidence / Observation	`curl -I https://testphp.vulnweb.com HTTP/1.1 200 OK [Strict-Transport-Security header: ABSENT] [Upgrade-Insecure-Requests: ABSENT]`
Business Impact	Users who access the site over HTTP (e.g. bookmarks, email links) can be intercepted by a network attacker who strips the HTTPS before it reaches the browser — a classic SSL Strip attack. The user sees no warning and believes they are secure.
Remediation	Add to server configuration: Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains" Also configure a permanent redirect (301) from HTTP to HTTPS at the server level.

F-06 Missing X-Frame-Options Header — MEDIUM

CVSS Score	Category
5.4 (Medium)	HTTP Security Headers
Description	No X-Frame-Options or Content-Security-Policy frame-ancestors directive is present. Without this header, the page can be embedded inside an on any external domain.
Evidence / Observation	`securityheaders.com scan result: X-Frame-Options: MISSING Frame-ancestors (CSP): MISSING Site can be embedded in iframes on external domains: YES`
Business Impact	Attackers can embed the target site in a transparent iframe overlaid on a fake page. When the user believes they are clicking a button on the attacker's page, they are actually clicking a button on the real site — transferring funds, changing settings, or confirming actions they never intended.
Remediation	Add to Apache configuration: Header always set X-Frame-Options "DENY" Or use the more modern CSP approach: Content-Security-Policy: frame-ancestors 'none'

F-07 Session Cookies Missing HTTP Only and Secure Flags — MEDIUM

CVSS Score	Category
5.9 (Medium)	Session Management

Description	Session cookies set by the application are missing both the HttpOnly flag (which prevents JavaScript from reading the cookie) and the Secure flag (which prevents the cookie being sent over plain HTTP).
Evidence / Observation	`Browser DevTools > Application > Cookies: Name: PHPSESSID Value: a8f3b2c1d4e5f6... HttpOnly: false <-- VULNERABLE Secure: false <-- VULNERABLE SameSite: [not set]`
Business Impact	If an XSS vulnerability exists anywhere on the site, an attacker can use document.cookie to steal the session ID and impersonate the logged-in user entirely — known as session hijacking. The Secure flag absence also means the session ID travels in cleartext over HTTP.
Remediation	Set cookie security flags in PHP configuration (php.ini): session.cookie_httponly = 1 session.cookie_secure = 1 session.cookie_samesite = Strict Or set programmatically: session_set_cookie_params(['httponly'=>true,'secure'=>true,'samesite'=>'Strict'])

F-08 Directory Listing Enabled on /images/ Path — MEDIUM

CVSS Score	Category
5.3 (Medium)	Information Disclosure

Description	The /images/ directory returns an Apache-generated directory listing instead of a 403 Forbidden or 404 response. This allows anyone to browse all files stored in that directory.
Evidence / Observation	`GET http://testphp.vulnweb.com/images/ HTTP/1.1 Response: 200 OK Body: Index of /images — Directory listing rendered Files visible: product images, uploaded user content, backup files`
Business Impact	Exposed file listings help attackers discover backup files (.bak, .sql, .zip), configuration files left in web-accessible directories, and sensitive uploaded content. It also confirms the directory structure of the application for further exploitation.
Remediation	Disable directory listing globally in Apache httpd.conf: Options -Indexes Or per-directory via .htaccess: Options -Indexes Return 403 for all directory requests.

F-09 Missing Referrer-Policy Header — LOW

CVSS Score 3.1 (Low)	Category Privacy / Headers
Description	No Referrer-Policy header is set. When a user navigates from this site to an external site, the full URL of the originating page (including query parameters) is sent in the HTTP Referer header.
Evidence / Observation	`curl -I https://testphp.vulnweb.com [Referrer-Policy header: ABSENT] Default browser behavior: full URL sent to external sites`
Business Impact	URLs may contain session tokens, search queries, or sensitive parameters. Without a policy, third-party analytics scripts, advertising networks, or external CDNs can see the full URL a user came from, representing a minor data privacy concern.
Remediation	Add: Header set Referrer-Policy "strict-origin-when-cross-origin" This is a one-line change with zero functional impact on the application.

F-10 Verbose PHP Error Messages Exposed — LOW

CVSS Score 3.5 (Low)	Category Information Disclosure
Description	PHP error reporting is enabled in production mode. When the application encounters an error, it returns the full PHP error including the server-side file path and line number directly in the HTTP response body.
Evidence / Observation	`GET /artists.php?artist=0 HTTP/1.1 Response body contains: Warning: mysql_fetch_array() expects parameter 1 to be resource in /var/www/html/artists.php on line 62`
Business Impact	The exposed file path (/var/www/html/) confirms the exact server layout to an attacker. Combined with other findings, this accelerates exploitation planning. It also indicates that error handling has not been hardened for production deployment.
Remediation	In php.ini: display_errors = Off | log_errors = On | error_log = /var/log/php_errors.log Errors should be logged server-side, never displayed to end users in production.

4. RISK CLASSIFICATION SUMMARY

The following table summarises all ten findings by risk level, CVSS score, and affected category. The overall security posture is rated **CRITICAL (Grade F)** due to the presence of four High-severity issues including an end-of-life PHP version, exposed Telnet, and complete absence of modern security headers.

ID	Finding	Risk	CVSS	Category	Fix Priority
F-01	Missing Content-Security-Policy	HIGH	7.4	HTTP Headers	Immediate
F-02	Weak TLS — v1.0 / 1.1 Accepted	HIGH	7.5	Transport Sec.	Immediate
F-03	Telnet Port 23 Open	HIGH	9.1	Open Ports	Immediate
F-04	Apache/PHP Version Disclosure	HIGH	6.5	Info Disclosure	Immediate
F-05	Missing HSTS Header	MEDIUM	6.1	HTTP Headers	This Month
F-06	Missing X-Frame-Options	MEDIUM	5.4	HTTP Headers	This Month
F-07	Insecure Session Cookie Flags	MEDIUM	5.9	Session Mgmt.	This Month
F-08	Directory Listing Enabled	MEDIUM	5.3	Info Disclosure	This Month
F-09	Missing Referrer-Policy	LOW	3.1	Privacy	Scheduled
F-10	Verbose PHP Error Messages	LOW	3.5	Info Disclosure	Scheduled

5. PRIORITIZED REMEDIATION PLAN

The following plan organises all findings into three action tiers based on risk level and remediation effort. Items are sequenced so that quick wins with high impact come first.

Fix Immediately — This Week

ID	Action	Effort	Impact	Implementation Note
F-03	Close Telnet port 23	1 hour	Extremely High	`sudo systemctl disable telnet; ufw deny 23/tcp`
F-04	Suppress server version headers	30 min	High	`ServerTokens Prod; Header unset X-Powered-By`
F-04	Upgrade PHP from 5.6 to 8.2+	2–4 hours	Critical	`Requires testing but eliminates 20+ known CVEs`
F-02	Disable TLS 1.0 and 1.1	1 hour	High	`SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1`
F-01	Add Content-Security-Policy	2 hours	High	`Start with report-only mode, then enforce`

Fix This Month

ID	Action	Effort	Impact	Implementation Note
F-05	Enable HSTS header	30 min	Medium	`max-age=31536000; includeSubDomains`
F-06	Add X-Frame-Options: DENY	15 min	Medium	`One-line Apache config change`
F-07	Set HttpOnly + Secure on cookies	1 hour	Medium	`php.ini: session.cookie_httponly=1`
F-08	Disable directory listing	15 min	Medium	`Options -Indexes in Apache config`

Schedule for Next Maintenance Window

ID	Action	Effort	Impact	Implementation Note
F-09	Add Referrer-Policy header	15 min	Low	`Header set Referrer-Policy strict-origin-when-cross-origin`
F-10	Disable PHP error display	15 min	Low	`php.ini: display_errors=Off; log_errors=On`
F-03	Evaluate & close FTP (port 21)	2 hours	Low–Medium	`Replace with SFTP if file transfer is needed`

Following remediation of all High and Medium items, a re-scan is recommended to verify fixes and obtain an updated security rating. Target posture: securityheaders.com grade A, SSL Labs grade A, zero High findings.

Report End — SecureAudit Pro

This document was produced for educational and portfolio purposes as part of a supervised cybersecurity learning exercise. All findings are based on passive, read-only analysis of the intentionally vulnerable testphp.vulnweb.com demonstration site. No systems were harmed in the production of this report.